Active Directory Security Exercise — Executive Debrief

> **Prepared by:** Kiemar **Exercise:** *Building and Breaking Active Directory* — hands-on lab (TryHackMe live class, 4+ hours) **Scenario modelled:** a retail bank ("TryBankMe") running Active Directory, with a third-party vendor sharing the same network **Date:** November 2026 **Audience:** IT leadership, risk, and non-specialist stakeholders

---

1. Executive summary

I completed a hands-on exercise in which I first **built** a realistic corporate Active Directory environment — the identity system that underpins logins, file access, and permissions across a Windows estate — and then, starting from **zero access and zero credentials**, worked my way up to **complete administrative control** of that same environment.

The headline finding is the most important one:

> **No software was hacked. No vulnerability was exploited. No security patch was missing.** Full compromise was achieved entirely through **ordinary configuration choices** — each one reasonable on its own — that chained together into a path from "outsider on the network" to "owns everything."

This matters because it reflects how the large majority of real-world Active Directory breaches actually happen. Organisations often assume that if their systems are patched and their antivirus is current, their identity infrastructure is safe. This exercise demonstrates concretely that it is the **accumulation of small, well-intentioned misconfigurations over time** — not exotic hacking — that most often hands an attacker the keys.

Outcome: starting with nothing, I reached the equivalent of total control over the bank's identity system in a documented sequence of six steps.

---

2. What was done, in plain language

The exercise had two halves.

Half one — I built the environment (the "administrator" role). I stood up a bank's Active Directory the way a real IT team would: created the central identity server, joined computers to it, organised servers and staff into logical groups, gave the help desk the ability to reset banking-staff passwords, and used central policy to grant an admin team rights across a set of servers. Every one of these is a normal, everyday administrative task.

Half two — I attacked it (the "adversary" role). All my administrative credentials were then revoked, and the environment was left in a realistic "lived-in" state — the kind of configuration drift that builds up in any organisation over years. From the position of an

attacker who has simply gained a foothold on the network (for example, through a phishing email or a compromised laptop), I attempted to regain control. I succeeded completely.

3. How the compromise unfolded

Each step below gave me a little more access, which I used to reach the next step. This is what security professionals mean by an **attack path**.

Step	What happened	Business-language explanation
1. **Looked around anonymously**	Found file shares readable by *anyone* on the network, no login required	Sensitive internal documents were left open to the public network, including an HR staff list and an IT onboarding memo
2. **Got my first login**	The onboarding memo contained a **default password** that one employee had never changed	A single reused, never-rotated password turned a public document into a working staff login
3. **Read the whole directory**	As an ordinary employee, I could read almost the entire company directory — and found a **password typed into a user's notes field**	Even a low-level account can see far more than most people assume; secrets stored in the wrong place are easily found
4. **Cracked a service account**	A behind-the-scenes "service" account had a weak, guessable password that I recovered offline	Automated service accounts are frequently over-privileged and under-protected
5. **Copied every password in the company**	That service account had been mistakenly granted the ability to **replicate the entire password database**	A permission granted to solve a past problem, and never removed, exposed every credential in the organisation
6. **Became the top administrator**	Using the stolen credential data, I logged in as the most powerful account with no need to know its password	At this point, the entire identity system — and everything it protects — was under my control

End state: complete administrative control of the bank's Active Directory. In a real organisation, this is the level of access from which an attacker can read any file, impersonate any employee, deploy ransomware estate-wide, or quietly maintain long-term presence.

4. Why this is a realistic and serious scenario

- **It required no advanced capability.** Every technique used is publicly documented and freely available. The barrier to entry is low.
- **Each weakness looked harmless in isolation.** The open share was created so a colleague could reach a file. The default password existed so the help desk could onboard

staff quickly. The over-powerful service account was granted its rights because something stopped working without them. **None of these are mistakes anyone would be fired for making** — and that is exactly why they persist.

- **No single person could see the whole picture.** The compromise was the *combination* of six decisions, made by different people, often years apart. This is the defining characteristic of Active Directory risk: it is **cumulative and organisational**, not a single technical flaw.
- **It is quiet until it isn't.** Most of these steps generate little that a typical monitoring setup would flag as alarming — until the attacker already holds the crown jewels.

---

5. Findings and risk ratings

#	Finding	Risk	Business impact if unaddressed
F1	File shares readable without any login (anonymous/guest access)	**High**	Direct leakage of staff data, internal documents, and credentials to anyone on the network
F2	Default onboarding password never rotated	**Critical**	Provides the initial foothold; converts a leaked document into a live account
F3	A password stored in a user's free-text notes field	**High**	Secrets in the wrong fields are readable by every employee and trivially harvested
F4	Service account with a weak, guessable password	**High**	Enables offline password cracking with no alerts; a classic escalation route
F5	Excessive permissions granted directly to a service account (ability to replicate all passwords)	**Critical**	Single most damaging finding — exposes the entire credential database
F6	Reliance on legacy authentication that treats a stolen credential fragment as a valid login	**High**	Allows "pass-the-hash" — login without ever knowing the real password

> **Note on severity.** F2 and F5 are rated Critical because each is, on its own, a decisive link in the chain. Fixing either one alone would have stopped the full compromise.

---

6. The good news: you don't have to fix everything

The single most reassuring takeaway is this: **breaking any one link in the chain stops the entire attack.** Defence does not require perfection — it requires closing enough gaps that the path no longer connects end to end.

Prioritised, plain-language recommendations:

Priority	Action	Addresses
1	**Audit file shares** — specifically, find everything an *unauthenticated* user can read, and lock it down	F1
2	**Eliminate default and never-changed passwords** — force a password change at first login and confirm it happened	F2
3	**Review powerful permissions, not just group memberships** — the most dangerous right in this exercise was invisible to a normal membership review	F5
4	**Harden service accounts** — long, automatically rotated passwords (modern "managed service accounts" do this for free)	F4
5	**Ban secrets in notes/description fields** — provide a proper password manager and scan for violations	F3
6	**Treat stored credentials as highly sensitive** — modernise authentication, and know that recovering from a serious compromise requires a specific reset procedure, not just changing one password	F6

One habit worth adopting organisation-wide: periodically look at your own environment the way an attacker would, and ask the simple question — *what can someone with no account at all already see on our network?* That single question would have surfaced the first and most damaging findings here.

---

7. What this exercise demonstrates about my capability

I deliberately chose a format that required me to play **both sides**: to build the environment as an administrator would, and then to compromise it as an adversary would. This gave me:

- **End-to-end understanding** of how identity infrastructure is configured *and* how those same configurations are abused — the "purple team" perspective that bridges offence and defence.
- **The ability to translate technical findings into business risk**, as in this document, alongside the deep technical record kept in the companion technical writeup.
- **Hands-on fluency** with the industry-standard tooling and methodology used in real Active Directory security assessments, practised over a 4+ hour live, hands-on session.

A full technical writeup — including the exact build steps, scripts, commands, and defensive controls for each finding — accompanies this debrief and is available for a technical audience.

---

8. Bottom line

An attacker starting with **nothing but a network connection** reached **total control** of a bank's identity system in six steps, using **zero software exploits**. Every step exploited a

configuration choice that looked entirely reasonable when it was made.

The lesson is not that the hypothetical bank was careless. The lesson is that Active Directory security is won or lost in **everyday decisions** — who can read which share, whether a default password gets changed, which account quietly holds one permission too many — and that reviewing those decisions regularly is far cheaper than recovering from the breach they enable.

Prepared by Kiemar. This exercise was conducted entirely within an isolated, authorised training environment that models — but is not — a real organisation. Findings are illustrative of common real-world Active Directory risks.